Architecting Production Agentic AI in Polish Banking: Strategy, Engineering Patterns, and Regulatory Execution

Diagnosis of the Consulting Failure: Why Slide-Deck AI Strategies Stall in Banking

Financial institutions across Europe and Poland have invested heavily in external advisory engagements over the past three years, yet the empirical return on these strategy-only initiatives remains exceptionally low[1]. Industry benchmarks established by MIT, IDC, and McKinsey demonstrate that while 77% of enterprises are actively exploring artificial intelligence, only 20% achieve measurable return on investment[1]. Across the broader corporate landscape, 88% of AI proofs-of-concept (PoCs) never transition into production, leaving 56% of organizations trapped in indefinite "pilot purgatory"[1]. When examining custom enterprise AI solutions specifically, the failure rate reaches 95%, standing in sharp contrast to generic, off-the-shelf large language model (LLM) chatbots, which achieve an 83% pilot-to-implementation rate precisely because they bypass core operational systems[1]. Consequently, two-thirds of financial sector executives have yet to record quantifiable productivity gains from AI, and one-quarter have paused or abandoned deployments altogether[4].

BANKING AI STRATEGY & ARCHITECTURAL FEASIBILITY REPORT

The **Strategy-Execution Gap** Drives an 88% Failure Rate in Enterprise AI Pilots

Diagnostic assessment contrasting slide-deck consulting roadmaps with production reality across financial institutions.

MACRO REALITY CHECK & POC ATTRITION

MIT, IDC & Industry Empirical Benchmarks

95%
Enterprise AI Failures
Solutions fail primarily from poor data foundations and lack of architectural integration.

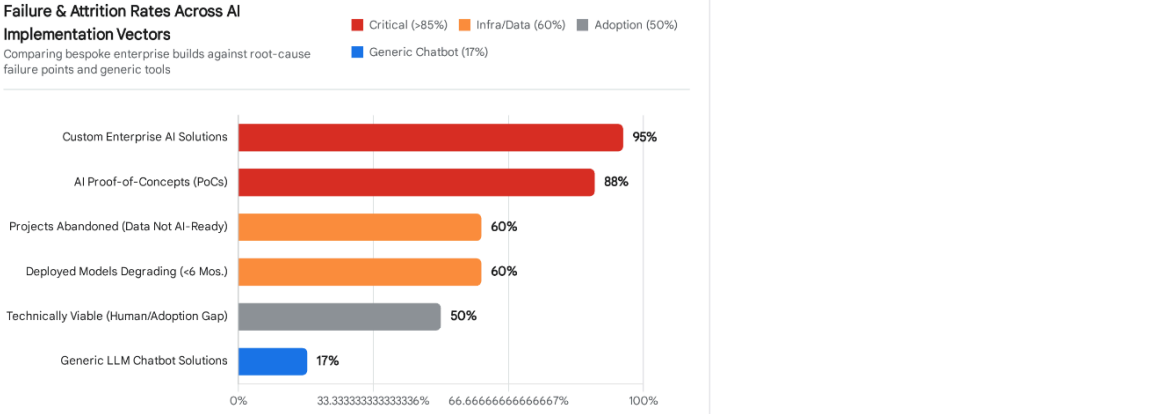
88%
PoCs Stalled
Proof-of-concepts never reach production due to the persistent strategy-execution divide.

67%
Zero Measurable ROI
Two-thirds of banking leaders have yet to demonstrate productivity gains from GenAI deployments.

56%
In "Pilot Purgatory"
Institutions indefinitely cycle parallel pilots without enterprise-scale deployment.

Failure & Attrition Rates Across AI Implementation Vectors

Comparing bespoke enterprise builds against root-cause failure points and generic tools



Key takeaway: Generic LLM chatbots reach production 83% of the time (17% failure), creating an illusion of maturity that masks the 95% breakdown in bespoke systems requiring deep banking integration.

The Cost of Strategic Failure Modes in Financial Institutions

Quantified budget destruction and execution delays caused by slide-only strategy and technical debt

TIMELINE PENALTY — **6 – 12 Months Lost**

Strategy-Only Consulting Roadmaps

Advisory roadmaps delivered without hands-on engineering feasibility. Internal bank teams lack data architecture and tooling to execute, requiring total rework or secondary procurement.

Root Cause: Architecture Absent — Zero Production Code

REWORK MULTIPLIER — **3x – 5x Cost Escalation**

Post-Hoc Governance & Data Retrofitting

Attempting to retrofit regulatory compliance, lineage tracking, and model explainability after development. Discovered data inconsistencies multiply implementation cost by up to 500%.

Root Cause: Governance Delay — 95% Failure Correlation

DIRECT CAPITAL WASTE — **$250K – $500K / initiative**

Technology-First Without Business Alignment

Building technically complex ML/LLM models without embedded domain sponsor buy-in or validated user workflow integration, yielding zero adoption at the operational branch or desk level.

Root Cause: Solution in Search of Problem — Zero Adoption

BUDGET DISSIPATION — **$150K – $400K / pilot**

Parallel Pilot Proliferation

Dispersing financial budgets across numerous uncoordinated department pilots without a shared core infrastructure platform, leading to 56% of banks staying permanently stuck in purgatory.

Root Cause: Fragmented Silos — No Path to Scale

PREMATURE TERMINATION — **Expecting Instant ROI (6–9 Month Sunk Write-off)**

Terminating projects after 6–9 months due to lack of quarterly ROI. Empirical banking data proves enterprise AI maturity requires 12–18 months; cutting initiatives early forfeits all invested capital and accumulated model learnings.

12–18 Mos.
Required Enterprise Runway

Empirical failure rates across enterprise AI initiatives and the associated financial and timeline penalties of common strategic errors. While generic chatbots reach production 83% of the time, **95% of custom enterprise solutions fail** primarily due to fragmented data foundations and the disconnection between slide-based strategy and production engineering.

Data sources: SoftTeco Research, Improving (IDC & MIT Studies), Cognizant Banking Insights

The primary mechanism behind the failure of traditional management consulting engagements in banking is the strategy-execution gap, which routinely costs institutions 6 to 12 months of lost progress before internal teams must re-architect and restart initiatives from scratch[1]. Generalist consulting firms typically deliver top-down use-case catalogs—listing plausible concepts such as automated underwriting, personalized wealth advisory, or document extraction—without verifying whether the underlying core banking systems, data lineage, and regulatory controls can support autonomous execution[2]. In a regulated bank, a model that performs well in an isolated sandbox fails in production because its outputs cannot be fed directly into core workflows or regulatory reporting pipelines without manual human reconciliation[6]. The bottleneck is never the raw capability of the foundation model; rather, scaling breaks down across three structural walls inside the institution[2].

The first structural barrier is the "data debt" tax and context fragmentation[2]. Approximately 95% of enterprise AI failures trace back to data constraints, and 60% of AI projects lacking AI-ready data are abandoned[1]. Industry surveys indicate that only 9% of financial institutions operate as truly "data-first organizations," while 14% still rely heavily on third-party digital providers for basic data access[4]. When consulting teams bypass foundational data engineering to build rapid PoCs on top of fragmented warehouses, data lakes, and legacy operational systems, the resulting agents lack authoritative business context[2]. Without a unified semantic layer, systems cannot reliably determine which data source is authoritative, which regulatory definition applies, or whether specific data is approved for consumption[6]. In banking, where a model hallucination constitutes a regulatory violation and a reputational crisis rather than a minor technical glitch, discovering these data gaps after development begins costs 3 to 5 times more than conducting an upfront architectural assessment[1].

The second barrier is the centralized operating model mismatch[2]. McKinsey research shows that 70% of financial institutions organize their AI efforts around a centrally led model, such as an isolated Center of Excellence (CoE) or an innovation lab[2]. While a centralized lab is effective at building standalone demonstrations, it is structurally unsuited for enterprise-wide scaling in a financial institution[2]. Centralized teams sit outside the business units that own the profit-and-loss (P&L) statements, leading to inter-departmental friction, slow execution, and a 40% to 60% failure rate driven by human factors and lack of frontline ownership[1]. Furthermore, up to 70% of potential business value is lost in the "final mile" of adoption when systems are designed as external IT projects rather than embedded natively into daily employee workflows[1].

The third barrier stems from retrofitted governance and MLOps neglect[1]. Treating compliance, model risk management, and explainability as a separate legal gate at the end of a pilot increases implementation costs by 3 to 5 times compared to embedding governance from day one[1]. Simultaneously, neglecting production MLOps infrastructure causes up to 60% of deployed models to degrade in effectiveness within six months due to data drift, correlation-driven errors on imbalanced datasets, and shifting macroeconomic conditions[1]. Organizations also routinely cancel initiatives prematurely after 6 to 9 months when expecting immediate payback, forfeiting returns that empirically materialize at the 12-to-18-month production maturity mark[1].

Strategic Dimension	Traditional "Big Four" Consulting Approach (Failure Mode)	Architecture-Led Banking Approach (Production Standard)	Quantified Impact / Risk Mitigation
Use-Case Selection	Brainstorming dozens of plausible slide-deck ideas across departments simultaneously[1].	Strict **Use-Case Triage** filtering out ideas that fail data lineage, risk, or legacy integration checks[5].	Avoids $150K$–400K wasted per abandoned pilot and $250K$–500K per misaligned tech-first project[1].
PoC Execution	Single "Demo Theater" PoC built on sanitized data and tested on friendly users to confirm bias[5].	**Parallel PoCs** tested on real users under production constraints against pre-written pass/fail criteria[5].	Eliminates "zombie pilots" that neither pass nor fail and drift for months without a funded business case[5].
Operating Structure	Centralized Innovation Lab / CoE disconnected from business unit P&L and core IT[2].	**Federated Hub-and-Spoke**: Central Hub governs infra/risk; Spokes embed engineers in P&L units[2].	Overcomes the 40%–60% failure rate caused by human factors and frontline adoption resistance[1].
Governance & Risk	Treated as a post-pilot legal gate before production sign-off[1].	**Continuous Co-Design**: UKNF, DORA, and EU AI Act controls built into the PoC harness from day one[5].	Eliminates the 3–5x cost multiplier of retrofitting explainability and compliance post-development[1].
ROI Horizon	Promising immediate 3-month transformational payback to win advisory phases[1].	**Disciplined Capital Allocation**: 90-day scoped production MVPs with enterprise ROI maturing at 12–18	Prevents premature cancellation at 6–9 months while capturing sustainable multi-year

		months[1].	efficiency[1].

To break out of this cycle, the Chief Architect must institute a Federated Hub-and-Spoke Operating Model paired with rigorous Use-Case Triage[2]. Under this architecture, the central Hub—led by Enterprise Architecture, Platform Engineering, and Model Risk Management—retains strict, non-negotiable control over core cloud and on-premise compute, enterprise data governance, ethical frameworks, the AI Gateway, Model Context Protocol (MCP) registries, and vendor procurement[2]. The Spokes embed AI engineers, data scientists, and domain specialists directly inside P&L-accountable business lines—such as Retail Lending, Corporate Banking, Fraud, and Wealth Management—ensuring that business leaders own the operational outcomes and frontline staff adopt the tools[2]. Every proposed initiative must pass a six-point architectural triage before a single line of code is written: verifying quantifiable business value with a named P&L owner, confirming data existence and legal permissibility, evaluating error blast radius, mapping regulatory exposure, proving integration viability with currently deployed legacy systems rather than hypothetical future architectures, and establishing a 90-day window to generate empirical evidence[5].

Empirical Benchmarks from the Polish Banking Sector (2025–2026)

A Chief Architect at a major Polish bank does not need to rely on theoretical international case studies; domestic competitors in Poland have already diverged sharply from slide-deck consulting to deploy high-impact production systems[11]. Analyzing the architectural choices of PKO Bank Polski, mBank, ING Bank Śląski, and Bank Pekao between 2025 and 2026 reveals a consistent engineering pattern: successful Polish deployments prioritize sovereign or hybrid compute control, employee augmentation over reckless customer-facing autonomy, and deep core-system modernization[12].

Polish Institution	Flagship Production AI & Agentic Initiatives (2025–2026)	Architectural & Infrastructure Posture	Measured Production Outcomes
PKO Bank Polski (PKO BP)	**Sovereign Email Routing Agent** (analyzing, classifying, and proposing execution paths for incoming client mail); **szukAI** corporate knowledge	**Sovereign AI & Proprietary LLMs**: In-house development of two Polish financial LLMs (1B and 24B parameters); open-source contributions to	Up to **70% faster** client email response across tens of thousands of monthly messages; **16,000+ internal users** on szukAI; roadmap of **30 additional AI**

	assistant; **Document Intelligence** (OCR + GenAI); **Visa Intelligent Commerce** pilot[12].	**Bielik** and **Sójka (Bielik-Guard)**[12].	**agents** in 2026[12].
mBank	**Talk to Your Data** (NL-to-SQL over tens of thousands of tables); **mComplaints** (GenAI complaint assistant); **Speech-to-Text & Automated QA**; **mKanon**; **mSmart** (corporate advisor synthesis); **Visa & Mastercard Agentic Payments**[13].	**Zero-PoC Internal Incubator & Core Replatforming**: Rejected isolated PoCs; built 100% in-house following complete migration from mainframe to **.NET**; **on-premise Speech-to-Text** to cap cloud opex[13].	**15% reduction** in average complaint handling time; **100% QA coverage** across 50,000 daily calls (10M annual interactions) vs. legacy 1-in-1,000 manual sampling[13].
ING Bank Śląski	**ING Business GenAI Assistant** (corporate banking conversational agent handling intent recognition, query resolution, and live specialist handoff)[14].	**Phased Corporate Portal Integration**: Pilot launched December 2025 inside authenticated ING Business environment with full rollout in Q1 2026[14].	Streamlined daily and transaction banking support for corporate users with deterministic human escalation[14].
Bank Pekao & UniCredit	**Mastercard Authenticated Agentic Transactions** (joint Polish production testing alongside mBank)[15].	**Cryptographic Agent Trust Layer**: Verifying cardholder authorization and trusted AI agent identity for autonomous purchasing[15].	Executed the first authenticated AI-agent-initiated payment transactions in Poland[15].

Three strategic lessons emerge from these Polish banking deployments that directly inform an

enterprise roadmap. First, core modernization and data discoverability must precede agentic scale[13]. mBank's ability to reject isolated PoCs and scale five major GenAI tools directly into production through its internal incubator stems from its structural engineering foundation: it is the first bank in Poland to have completely migrated both retail and corporate banking off legacy mainframes onto a modern .NET architecture[13]. Furthermore, recognizing that data analysts spend more time locating data across tens of thousands of database tables than analyzing it, mBank deployed *Talk to Your Data*—an internal natural-language-to-SQL agentic tool equipped with reinforcement feedback loops from analysts—to accelerate regulatory reporting and system specification checks[13].

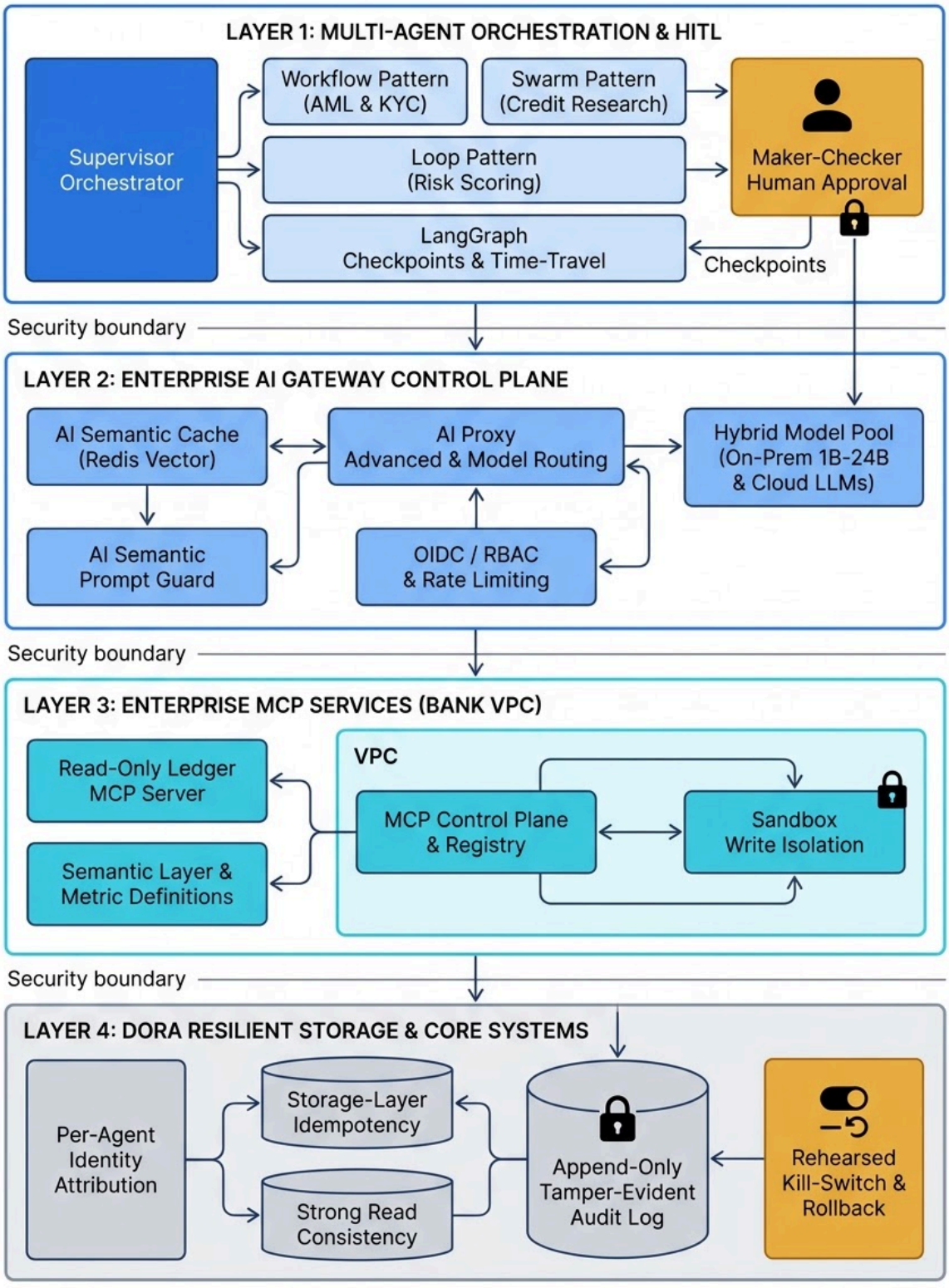
Second, unit economics dictate hybrid and on-premise inference for high-volume operational workloads[13]. While public cloud APIs accelerate initial experimentation, mBank demonstrated strict architectural discipline in its contact center operations[13]. Processing 50,000 voice calls per day—totaling 10 million customer interactions annually—through public cloud speech-to-text APIs generates punitive recurring operational expenditure[13]. By deploying speech-to-text models on-premise via a one-time capital allocation and applying generative AI for automated post-call synthesis and quality assurance, the bank transitioned from manually auditing 1 in 1,000 or 1 in 10,000 calls to delivering automated compliance feedback on 100% of customer conversations[13].

Third, Sovereign AI and domain-specific small-to-medium models are replacing monolithic external dependencies[12]. By August 2026, 40% of multinational enterprises globally began redesigning their AI deployment strategies to satisfy Sovereign AI mandates, where both data residency and model training or hosting remain within national borders[19]. PKO Bank Polski exemplifies this architectural posture in Poland: rather than relying exclusively on foreign hyperscaler APIs, PKO BP developed two internal Polish-language generative models specialized in finance—sized at 1 billion and 24 billion parameters—alongside contributing to the Polish open-source model ecosystem, including *Bielik* and the safety classifier *Sójka (Bielik-Guard)*, which has surpassed 900,000 downloads on Hugging Face[12]. Crucially, PKO BP built its *szukAI* corporate knowledge platform (adopted by over 16,000 employees) and its *Document Intelligence* pipeline first, establishing the verified retrieval foundation required to power its first sovereign email-routing agent and its broader 2026 roadmap of 30 additional operational AI agents[12].

Enterprise Reference Architecture for Agentic Banking Systems

Transitioning from basic conversational assistants to Agentic AI shifts the paradigm from task-level text generation to autonomous, multi-step workflow execution across disparate systems, teams, and decision boundaries[20]. In a banking environment, however, probabilistic foundation models cannot be granted unconstrained autonomy over deterministic financial ledgers[6]. To satisfy both engineering reliability and regulatory auditability, the Chief Architect must implement a four-layer governed agentic stack: Multi-Agent Orchestration and Execution Patterns, the Enterprise AI Gateway Control Plane, Standardized Context and Tooling via

Enterprise MCP Services, and a DORA-Compliant Transactional Storage Layer[10].



Layer 1: Multi-Agent Patterns, LangGraph Orchestration, and

Maker-Checker Controls

Production banking architectures must align the specific multi-agent coordination topology with the risk profile, latency tolerance, and dependency structure of the underlying banking workflow[22]. Rather than treating all agentic systems as uniform autonomous loops, enterprise architects categorize multi-agent topologies into four distinct patterns alongside two prohibited anti-patterns[22].

Agentic Pattern / Anti-Pattern	Architectural Mechanism & Reasoning Paradigm	Primary Banking & Financial Services Use Cases	Operational Trade-Offs & Governance Constraints
Workflow Pattern (Sequential & Parallel)	Decomposes complex processes via chain-of-thought into deterministic steps where each agent validates output before passing state forward[22].	**AML/KYC Compliance** (ID verification to PEP screening and enhanced due diligence); **Autonomous Claims & Dispute Adjudication**[22].	Delivers high accuracy and linear regulatory audit trails, but overall latency is bounded by the slowest agent in the chain[22].
Swarm Pattern (Collaborative Concurrent)	Multiple specialized agents execute concurrently over shared memory and foundation models to synthesize heterogeneous inputs[22].	**Equity & Credit Research** (parallel agents analyzing stock prices, financial metrics, company profiles, and news sentiment)[22].	Compresses multi-hour analyst research into minutes, but requires strict shared-memory coordination[22].
Loop Pattern (Reflective Reasoning)	Iterative processing cycles where evaluation agents critique and refine outputs against quality thresholds until convergence[22].	**Credit Scoring Refinement**, **Algorithmic Trading Simulation**, and **Dynamic Pricing Optimization**[22].	Enables dynamic self-improvement, but requires strict termination conditions to prevent runaway infinite loops and token exhaustion[22].
Hybrid	Supervisor	**Enterprise**	Provides clear

Hierarchical Pattern	orchestrator directs specialized sub-agents sequentially for governance while running compute-heavy tasks in parallel[25].	**Platforms** (exemplified by JPMorgan Chase's *OmniAI* managing hundreds of domain sub-agents across business units)[25].	regulatory accountability chains, though supervisor capacity must be engineered to avoid bottlenecks[25].
Anti-Pattern: Large Singleton *(Prohibited)*	Overloading a single agent with excessive tools and responsibilities (e.g., risk modeling, commissions, broker chat, and KB search)[22].	Misconfigured monolithic underwriting or customer service agents[22].	Causes tool confusion, malformed function arguments, inconsistent outputs, high latency, and inflated token costs[22].
Anti-Pattern: Agent Washing *(Prohibited)*	Wrapping a single deterministic script, Lambda function, or single tool inside a multi-agent supervisor purely for marketing optics[22].	Over-engineered simple automation workflows[22].	Introduces unnecessary orchestration latency and failure points where deterministic API calls suffice[22].

For the macro-orchestration runtime, banking engineering teams are standardizing on graph-based stateful orchestration frameworks such as LangGraph, often deployed alongside managed cloud runtimes including AWS Bedrock AgentCore, Strands Agents, Microsoft Azure AI Foundry, or IBM watsonx[22]. Unlike unconstrained autonomous agent loops, LangGraph models workflows as explicit state graphs supporting interrupt-and-resume checkpoints and time-travel debugging[28]. This capability enables the architectural enforcement of banking's foundational Maker-Checker rulebook: the AI agent acts as the "Maker" by gathering KYC evidence across jurisdictions, drafting credit memos, or preparing payment instructions, and execution pauses deterministically at a graph checkpoint until an authorized human "Checker" reviews, modifies if necessary, and cryptographically approves any action that moves money, exceeds transaction thresholds, or communicates with a regulator[26].

Layer 2: The Enterprise AI Gateway Control Plane

Allowing individual banking applications or agents to call external or internal LLM APIs directly creates unmanageable security, cost, and compliance sprawl[9]. Every request—whether User-to-LLM, Agent-to-Agent (A2A), or Agent-to-Tool via MCP—must traverse a centralized

Enterprise AI Gateway[9]. A critical architectural decision for the Chief Architect is selecting between developer-centric proxies such as LiteLLM or Portkey, managed AI gateways such as TrueFoundry, and enterprise API control planes such as Kong AI Gateway[34]. While LiteLLM offers rapid configuration-based model switching across providers, its open-source core decentralizes governance into application-level virtual keys, lacks unified precedence rules when rate limits overlap across keys, teams, and users, and does not provide standard enterprise patching SLAs or SLSA attestations—frequently turning into a costly internal reliability project as scale increases[24]. Conversely, extending an enterprise API management platform like Kong AI Gateway unifies APIs, event streams, LLM calls, MCP tool invocations, and A2A traffic under a single policy layer integrated with corporate OIDC, LDAP, and SAML identity providers[24]. In production stress benchmarks running 400 concurrent virtual users with 1,000-token prompts across 12 CPUs, Kong's data plane demonstrated over 200% higher throughput than Portkey and over 800% higher throughput than LiteLLM[34].

Regardless of vendor selection, the bank's AI Gateway must enforce four foundational capabilities across the request lifecycle[9]. First, the gateway must implement vector-based semantic caching by embedding incoming prompts (for example, via text-embedding-3-large or sovereign local embeddings) and querying a high-speed vector store such as Redis 8.0 to identify semantically equivalent prior queries[9]. Returning cached validated responses without invoking the underlying LLM reduces monthly inference token costs by 40% to 70% and compresses response latency from 850 milliseconds to under 120 milliseconds, representing a 3-to-4x average speedup and up to 10x acceleration on repetitive banking queries[9]. Second, the gateway must layer semantic prompt guarding and inline runtime security over traditional regex allow/deny lists[34]. Semantic prompt guards block prohibited intents or off-topic domains regardless of phrasing, while inline security evaluators such as Straiker inspect request context before an agent action executes[34]. Third, the gateway must provide semantic routing and model lifecycle management, treating fine-tuned domain models (such as separate Retail Banking and Mortgage & Lending assistants) and sovereign models (like PKO BP's 1B and 24B parameter models) as versioned products supporting blue/green deployments, canary releases, and multi-cloud failover[12]. Fourth, the gateway must enforce granular rate limiting and token budget ceilings composed across consumer, team, route, and service tiers to prevent cost overruns[24].

Layer 3: Standardized Context and Tooling via Enterprise MCP Services

The primary reason enterprise AI agents stall before production is the inability to safely connect models to fragmented internal systems of record without building brittle point-to-point API integrations or suffering from "Context Rot"[6]. Anthropic's open Model Context Protocol (MCP)—operating via JSON-RPC 2.0 messages across an MCP Host (the AI application), MCP Clients (connectors), and MCP Servers (which expose curated tools and data resources)—has emerged as the universal standard for financial services[38]. Across financial institutions implementing MCP for lending, accounts payable three-way matching, and risk analysis, organizations report cutting manual processing work by 60% to 70%, improving fraud detection accuracy by 50%, increasing customer satisfaction by 30%, and achieving positive ROI within 5

months[8].
However, the Chief Architect must enforce a strict architectural distinction: the MCP specification explicitly leaves access control to the implementer and cannot guarantee security at the bare protocol level[39]. Most early open-source MCP servers are local-first, desktop-centric, single-player implementations lacking multi-tenancy and governance[10]. A regulated bank must instead deploy Enterprise MCP Services—leveraging VPC-hosted platforms such as Stacklok/ToolHive, Arcade, or custom in-house implementations like Block—that run entirely inside the bank's Virtual Private Cloud so sensitive data never leaves the institution's infrastructure[10]. To maintain operational velocity in financial workflows, production MCP services must engineer for strict latency thresholds: under 100 milliseconds for context retrieval (with a 300-millisecond maximum ceiling) and under 200 milliseconds for standard API tool responses (with a 500-millisecond critical threshold)[10].
Connecting any AI agent to financial ledgers or customer data via MCP requires enforcing seven mandatory governance controls across finance, data engineering, and internal audit teams[8]. First, under the ownership of the group controller, teams must strictly scope data exposure to mapped general ledgers, consolidation tables, and metric definitions while stripping out raw ERP exports, payroll records, and bank credentials, and passing only tokenized cardholder or account data to fraud and risk agents so the LLM never views raw personally identifiable information[8]. Second, finance systems leads must match and isolate MCP servers by job boundary, running separate servers for external market data, single-ERP transaction workflows, and cross-entity consolidated reporting[39]. Third, configurations must default to read-only access by verifying that the server's actual exposed tool list contains zero write tools rather than trusting client-side read-only metadata annotations, which the MCP specification treats as untrusted[39]. Fourth, security architects must enforce per-person and per-agent OAuth under the user's specific role-based access control (RBAC) identity, strictly prohibiting shared administrator tokens[39]. Fifth, FP&A leads must ground every agent query in a governed semantic layer (such as Keboola Financial Intelligence), forcing the assistant to load formal metric definitions, unified chart-of-accounts mappings, currency conversion rules, and fiscal calendars before generating SQL[39]. Sixth, controllers and data engineers must isolate all writes so that any agent-generated changes to data or reporting logic are routed to a sandbox or development branch requiring a named human approver, keeping final ledger posting inside the core banking ERP's deterministic workflow[39]. Seventh, internal control teams must review the MCP tool-call log during periodic financial close exactly like a privileged access log, integrating records with enterprise SIEM platforms such as Splunk or Datadog and filing them with close audit evidence[39].

Layer 4: DORA-Compliant Transactional Storage and Operational Resilience

When an agentic system transitions from an internal pilot to a customer-facing or operations-scale service running hundreds of concurrent read → decide → write → verify loops per second, traditional database architectures exhibit severe failure modes[23]. Under the EU Digital Operational Resilience Act (DORA) and EU AI Act Article 12, database infrastructure is

no longer merely a persistence tier; it is the primary compliance evidence generator[7].

Storage & Resilience Control	Architectural Implementation in the Banking Estate	Failure Mode if Omitted at Agent Scale	Regulatory Mandate Satisfied
Append-Only Audit Storage	Immutable, tamper-evident write-once logs enforced directly at the database storage layer capturing agent ID, tool arguments, results, policy checks, and synchronized timestamps[7].	Mutable application logs can be altered by administrators or attackers, invalidating forensic reconstruction during regulatory audits[7].	**DORA** (Logging & Event Reconstruction) & **EU AI Act Art. 12 & Art. 18** (10-year record retention)[7].
Per-Agent Identity Attribution	Every database write and state transition carries a dedicated cryptographic agent identity linked to its authorizing human/system policy[7].	Shared service accounts make it impossible to reconstruct which agent executed an erroneous transaction or under what authority[23].	**DORA Art. 9** (IAM Controls) & **EU AI Act Art. 12** (Traceability)[23].
Strong Read Consistency	Distributed SQL architecture guaranteeing linearizable, strong read consistency across all database nodes globally or regionally[23].	Agents acting on stale reads across asynchronous replicas trigger race conditions, double-spends, and duplicate credit issuances at machine speed[23].	**DORA** (Transaction Integrity & Operational Resilience)[23].
Storage-Layer Idempotency	Enforcing idempotency keys natively at the	Network timeouts trigger automatic agent tool retries,	**DORA** (ICT Risk Management & Payment Integrity)[7].

	database storage tier rather than relying on application-layer deduplication[23].	resulting in duplicate payments or ledger postings under concurrent load[23].	
Compensating Transactions & Kill-Switch	Automated rollback paths for partial workflow failures paired with an isolated, per-agent **Kill-Switch** and dual-control restart[7].	Inability to halt a malfunctioning agent without taking down core banking services or leaving orphaned, unreconciled ledger states[7].	**DORA Art. 24–27** (Resilience Testing) & **EU AI Act Art. 14** (Human Intervention/Stop)[7].

A mandatory operational ritual for the Chief Architect under this architecture is the Rehearsed Kill-Switch Drill[7]. Just as infrastructure teams test disaster recovery failover, banking AI teams must periodically trigger an emergency stop on a production agent without disrupting adjacent agents or core banking systems, verify mathematically that zero tool invocations or writes occur after the stop decision, produce the complete write manifest with automated rollback paths or named remediation owners, and prove that restarting the agent requires recorded cryptographic approval from a different authorized individual[7].

Navigating the Polish & EU Regulatory Trilemma: UKNF, EU AI Act, and DORA

A common misconception in financial institutions is treating the EU AI Act, DORA, and Polish national supervision (UKNF) as separate legal workstreams requiring duplicate compliance bureaucracy[7]. As the European Banking Authority (EBA) confirmed in its landmark November 21, 2025 factsheet (*AI Act: implications for the EU banking and payments sector*), the EU AI Act contains no significant contradictions with existing EU financial services legislation; rather, its requirements layer directly onto existing sectoral frameworks[42]. The Chief Architect's objective is to design a Single Governed-Agent Control Set where one architectural mechanism satisfies all three regulatory regimes simultaneously[7].

BANKING AI COMPLIANCE BLUEPRINT & ARCHITECTURE

Regulatory Convergence Timeline and Control Mapping for **Polish Banking AI** (2025–2027)

Interactive dual-track view for Chief Architects: Chronological regulatory enforcement dates (top) aligned with a unified architectural control matrix across the EU AI Act, DORA, and Polish UKNF requirements (bottom).

1. Enforcement Milestones & Standardization Horizon

Select any milestone to reveal corresponding architectural deliverables & legal exposures.

All (9) | AI Act | DORA | UKNF / EBA

Jan 17, 2025 DORA In Force — Regulation (EU) 2022/2554
DORA Full Application (Directly Binding EU Law)
Applies directly across all 21 categories of financial entities. Strict 4-hour major incident reporting & resilience frameworks activate.
Fines up to 2% global turnover

Feb 2, 2025 EU AI Act — Article 5 Prohibitions
Prohibited AI Practices Enforceable
Total ban on social scoring, untargeted biometric scraping, and cognitive behavioral manipulation. Bank AI registry required.
Fines up to €35M / 7% turnover

Nov 21, 2025 EBA Factsheet — Banking Sector Mapping
EBA Confirms Credit Scoring & AML as High-Risk
Affirms alignment with existing financial directives. Flags unresolved high-risk status of algorithmic trading systems.
Scope Clarification

Feb 2, 2026 EC Mandate — Classification Guidelines
European Commission High-Risk Classification Guidelines
Statutory deadline for the EC to publish binding guidance defining high-risk perimeter exceptions and edge cases.
6-Month Runway Left

Mid-2026 NCA / UKNF — Supervisory Inspections
Supervisors Expect Demonstrable High-Risk Progress
EBA guidance instructs NCAs (including UKNF) to audit draft Annex IV technical files and Model Risk governance.
Audit Exposure

Aug 2, 2026 CRITICAL DEADLINE — Annex III High-Risk Enforcement
Full Compliance Mandatory: Credit Scoring, Underwriting, & AML AI
No Grandfather Clause: Legacy models deployed before Aug 2024 must achieve full compliance. Mandatory Articles 9–15 conformity, logging (Art. 12), and EU registration.
Fines up to €30M / 6% turnover

⚠ **ARCHITECTURAL ALERT: THE ARTICLE 12 LOGGING STANDARDIZATION GAP (AUG 2026 VS Q4 2026+)**
High-Risk legal enforcement activates on Aug 2, 2026, mandating automatic audit-trail logging (Art. 12). However, CEN-CENELEC's harmonized technical standard **ISO/IEC DIS 24970 Clause 8.3.1** will not be finalized until **Q4 2026 at the earliest.** Polish banks cannot wait for standardized vendor packages: architecture teams must implement self-assessed, immutable event logs using DORA run-record primitives immediately.

Q4 2026+ CEN-CENELEC JTC 21 — ISO/IEC DIS 24970
Earliest Finalization of AI Logging Technical Standard
Clause 8.3.1 codifies auditability of ML model state information and decision pathways after the legal high-risk deadline has passed.
Lagging Standard

Aug 2, 2027 Transition Horizon — Article 111 AI Act
Article 111 Transition Closes (Existing Regulated Products)
Digital Omnibus window expires. High-risk systems embedded in pre-existing large products reach final statutory transition date.
Final Window

ACTIVE INSPECTION: AUG 2, 2026 — EU AI ACT • ANNEX III ENFORCEMENT

Mandatory High-Risk AI System Enforcement & Conformity Assessment

All credit assessment, credit scoring, and AML transaction monitoring systems in production must meet Articles 9–15 obligations. Because **no grandfather clause applies**, any legacy model deployed prior to August 2024 is strictly subject to conformity requirements.

KEY REGULATORY ARTICLES	ENGINEERING DELIVERABLE	NON-COMPLIANCE EXPOSURE
Articles 9, 10, 12, 14, 18; Annex III item 5(b) & 6; Annex IV	Self-assessed Annex IV technical documentation file & 10-year retention archive	Up to €30,000,000 or 6% of total global annual turnover

2. Unified Architectural Control Mapping Matrix

How a single robust technical architecture satisfies EU AI Act, DORA resilience, and Polish UKNF requirements simultaneously.

Architectural Control	EU AI Act (2024/1689)	DORA (EU 2022/2554)	Polish UKNF Mandates
1. Immutable Logging & Decision Replay WORM-compliant run records & decision pathways	**Article 12:** Automatic event logging across operational lifetime. Auditability of input vectors, model state, and scoring output.	**Articles 5–16:** Replayable run records, unique agent identity per action, tool invocation records, tamper-evident logs.	**Komunikat Chmurowy:** Mandatory log collection and continuous monitoring in cloud environments.
2. Model Risk & Data Governance Inventory, bias checks, and lifecycle audits	**Articles 9 & 10:** Continuous documented risk management; datasets must be representative, error-free, and vetted for bias.	**Articles 5–16:** ICT risk management framework approved and continuously reviewed by executive management body.	**Rekomendacja W (Rek 1, 4, 8):** Complete Model Register for 100% of models; formal criteria for data preparation and model quality.
3. Human Oversight & Kill-Switch Operational override & rollback drill	**Article 14:** Human-in-the-loop oversight with genuine operational capacity to pause, reverse, or override credit decisions.	**Articles 24–27:** Rehearsed "stop drill" kill-switch: zero downstream writes post-stop, write list rollback, two-person restart sign-off.	**Stanowisko AML & Rek. W:** Documented executive sign-off; designated deputy roles for board member (Art. 7) & AMLRO (Art. 8).
4. Third-Party & Cloud Vendor Controls LLM API, cloud hosting, and exit strategies	**Articles 13 & 25:** Upstream provider vs deployer responsibility boundaries; 10-year conformity document retention.	**Articles 28–44:** Register of information for ICT third-party arrangements, mandatory audit rights, and viable exit/portability plans.	**Komunikat Chmurowy:** UKNF notification within 30 days of production start; strict "outsourcing szczególny" compliance.
5. Incident Escalation & Post-Market Root cause reconstruction under regulator deadlines	**Article 73:** Serious incident reporting and mandatory continuous post-market surveillance system for high-risk models.	**Articles 17–23:** Initial notification to competent authority within 4 hours of major ICT incident classification.	**UKNF Oversight:** Audit findings for procedure deficiencies (19.39% of 2024 KNF AML irregularities involved internal governance).

Tip: Click any matrix row to populate specific technical architecture recommendations in the inspector above.

Chronological enforcement milestones and architectural convergence across EU and Polish banking regulations. Because **no grandfather clause** applies to legacy high-risk systems and harmonized CEN-CENELEC logging standards (ISO/IEC DIS 24970) lag behind enforcement, Polish banks must implement self-assessed conformity and unified DORA/UKNF logging controls immediately.

Data sources: European Banking Authority (EBA), UKNF Rekomendacja W, UKNF Komunikat Chmurowy (EY), UKNF Stanowisko AML/CFT, Alice Labs, Zenity DORA Research, Moring.ai, Veritas Chain

The EU AI Act (Regulation 2024/1689) and the Standardization Gap

Under Annex III of the EU AI Act, banking systems are not classified as high-risk merely because the deployer is a bank; classification is strictly use-case driven[48]. Two core banking domains fall unambiguously under the High-Risk Annex III regime, carrying administrative fines of up to €30 million or 6% of global annual turnover, with no grandfather clause exempting legacy systems deployed prior to August 1, 2024[42]. The first high-risk domain is Creditworthiness and Credit Scoring under Annex III, Point 5(b), which encompasses any AI system evaluating retail or corporate credit applications, mortgage approvals, or robo-advisors that incorporate creditworthiness or financial capacity assessments[42]. The second high-risk domain is AML/CFT Transaction Monitoring and Fraud Detection under Annex III, Point 6; the EBA's November 2025 mapping report explicitly confirmed that AI used for Anti-Money Laundering and Counter-Terrorist Financing transaction monitoring at supervised institutions falls under high-risk obligations, whereas pure payment fraud detection devoid of AML elements requires individual classification assessment[42]. Conversely, pure algorithmic trading systems without individual credit assessment were deliberately left unclassified in the EBA's November 2025 factsheet, creating a "Schrödinger's compliance" state pending European Commission classification guidelines mandated for February 2, 2026[42].

For all High-Risk systems, the Chief Architect must engineer compliance across Articles 9 through 15 and Article 18: establishing an ongoing Risk Management System integrated into enterprise risk procedures (Article 9), enforcing error-free and representative Data Governance across training, validation, and test sets (Article 10), compiling the 12 mandatory elements of Annex IV Technical Documentation retained for 10 years post-deployment via self-assessed conformity (Article 11 and Article 18), enabling automatic decision and input/output event logging (Article 12), providing deployer transparency (Article 13), and building genuinely operable Human Oversight capable of reviewing, stopping, or overriding any automated decision (Article 14)[42]. Note that for credit scoring models, retraining on a fundamentally different dataset, changing the target variable, or deploying the model in a new product context triggers re-assessment, whereas routine parameter retuning within defined thresholds typically does not[42].

Crucially, the Chief Architect must navigate a severe regulatory timing mismatch: while High-Risk Annex III obligations carry a primary enforcement deadline of August 2, 2026 (with select transitions for high-risk AI embedded in existing regulated products extending to August 2, 2027 under Article 111 and the European Commission's Digital Omnibus proposal), the harmonized European technical standard governing *how* to log AI decisions—CEN-CENELEC JTC 21's draft standard ISO/IEC DIS 24970 under standardization request M/593/Amendment M/613—will not be finalized until Q4 2026 at the earliest[23]. Rather than waiting for final CEN-CENELEC publication, the bank's logging architecture must proactively implement Clause 8.3.1 of ISO/IEC DIS 24970, which mandates full auditability of both ML model state information (weights, version, temperature, system prompt, and active adapters) and decision pathway data (the exact chain of MCP tool calls, retrieved RAG context chunks, and intermediate agent state transitions)[7].

DORA (Regulation 2022/2554) as the Operational Estate Layer

Whereas the EU AI Act governs the safety and fairness of the AI system itself, DORA—fully applicable as binding EU law since January 17, 2025—governs the operational resilience of the ICT estate in which the AI agent acts[7]. Non-compliance exposes a financial entity to fines reaching 2% of total worldwide annual turnover, up to €5 million for critical ICT third-party providers, and up to €1 million in personal liability for individual Management Board members[50]. DORA structures its obligations across five pillars: ICT risk management, incident management and reporting, digital operational resilience testing (including annual testing for all entities and threat-led penetration testing every three years for significant institutions), ICT third-party risk management, and information sharing[50].

Because an AI agent that modifies records or initiates payments is an "ICT-supported function," every production agent must be registered as an ICT asset with a documented risk assessment proportionate to its potential harm, scoped permissions rather than model promises, and named deployment accountability (Articles 5–16)[7]. Furthermore, DORA's Incident Management and Reporting pillar (Articles 17–23) mandates that any major ICT incident—such as an autonomous agent executing a consequential erroneous action—must be classified and reported to the competent authority (UKNF) on a strict timeline: an initial notification within 4 hours of classification, followed by intermediate and final forensic reports[7]. Without the replayable run records and append-only database logs detailed in Layer 4, reconstructing an agent's multi-step trajectory within a 4-hour regulatory window is impossible[7]. Finally, under DORA Articles 28–44 (ICT Third-Party Risk Management), every external LLM API provider, cloud hyperscaler, and agent platform vendor is an ICT third-party dependency that must be logged in the bank's Register of Information (reported annually to supervisors) with binding contractual clauses covering data use, audit rights, change notices, concentration risk, data residency, and exit strategies[7]. Deploying models and MCP services inside the bank's own Virtual Private Cloud converts the hardest third-party questions into internal architectural controls[7].

Polish National Supervision (UKNF): Rekomendacja W, Cloud Communiqué, and AML/CFT

In Poland, the Chief Architect must map the agentic stack directly onto three specific supervisory instruments enforced by the *Urząd Komisji Nadzoru Finansowego* (UKNF)[52]. The first instrument is *Rekomendacja W* (issued under KNF Resolution 332/2015 concerning model risk management in banks), which explicitly encompasses machine learning, random forests, decision trees, and deep learning neural networks within its regulatory perimeter[54]. Under Recommendations 1, 4, 8, and 9 of *Rekomendacja W*, a Polish bank must integrate all utilized and planned models into its enterprise Model Risk Management (MRM) process across their entire lifecycle, regardless of materiality, data type, or whether the model is developed internally (*model wewnętrzny*) or supplied by an external vendor (*model zewnętrzny*)[54]. For every LLM or scoring agent deployed, the bank must update its formal Model Register (*Rejestr modeli*), maintain granular Model Logs (*Dzienniki modeli*) to support ongoing statistical monitoring and independent validation, and obtain comprehensive technical documentation detailing key model elements, training data, assumptions, and inherent limitations even for third-party foundation

models[54]. Applying the Principle of Proportionality (*Zasada proporcjonalności*) defined in *Rekomendacja W* allows the Chief Architect to calibrate validation effort to model materiality—applying streamlined controls to non-material internal productivity assistants while enforcing rigorous statistical monitoring, acceptance criteria, and residual risk controls on material credit, market, operational, or liquidity models[54].

The second Polish supervisory instrument is the *Komunikat Chmurowy UKNF* (Polish Cloud Computing Communiqué), which governs any AI workload processed in a public cloud or a hybrid cloud to the extent it utilizes public cloud infrastructure[53]. Before processing information in the cloud, the bank must classify the information (accounting for legally protected secrets such as Polish banking secrecy), perform continuous risk estimation grounded in PN-ISO 27005 (or an equivalent standard) utilizing the iterative Deming cycle across general cloud threats, service-specific threats, and internal resource threats, and implement all risk mitigation controls prior to launch[53]. The bank must also maintain registers of cybersecurity personnel, network topology, and business continuity plans, collect and process cloud environment logs continuously, and notify UKNF no later than 30 days after commencing cloud service usage[53]. Reassessment is mandatory whenever the bank processes a new category of information, adopts a new cloud AI service, significantly alters processing scale, or faces regulatory or contractual changes[57].

The third Polish instrument is the *Stanowisko UKNF dot. Procesów AML/CFT* (consulted with the General Inspector of Financial Information, GIIF, and read alongside GIIF Communiqués 35–38 and EBA Guidelines EBA/GL/2021/02)[52]. In 2024, deficiencies in internal AML/CFT procedures accounted for 19.39% of all AML/CFT irregularities detected by KNF—more than double the rate recorded in 2021[52]. UKNF strictly penalizes both missing procedures and "facade procedures" (*fasadowość*) under Article 147 Point 7 of the Polish AML Act[52]. Consequently, introducing AI or agentic workflows into AML/CFT processes requires updating the bank's internal AML/CFT Procedure across the 11 statutory areas (plus additional risk-specific controls for high-risk products or outsourcing) and securing documented, timestamped approval from Senior Management—specifically the designated Management Board member under Article 7 and the AMLRO under Article 8, both of whom must have formally appointed deputies[52].

Operationalizing Runtime Assurance: NIST AI 600-1, ISO 42001, and AIUC-1

To bridge high-level legal mandates with daily engineering execution, the Chief Architect should adopt three complementary international standards as the internal evaluation harness[59]. The first is NIST AI 600-1 (*Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile*, published July 26, 2024), which extends the voluntary NIST AI RMF 1.0 functions (Govern, Map, Measure, Manage) with 12 GAI-specific risk categories and 212 suggested actions across 49 subcategories, focusing on four primary considerations: Governance, Content Provenance, Pre-deployment Testing, and Incident Disclosure[60]. The 12 risk categories—CBRN information, Confabulation, Dangerous/violent/hateful content, Data privacy, Environmental impacts, Harmful bias or homogenization, Human-AI configuration,

Information integrity, Information security, Intellectual property, Obscene/degrading/abusive content, and Value chain and component integration—provide an auditor-ready risk register vocabulary[61]. In a banking deployment, two NIST risks require immediate architectural prioritization: Confabulation (confidently stated false content regarding fees, rates, or account statuses, which regulators such as the CFPB classify as deceptive practices) and Human-AI Configuration (specifically mitigating automation bias, over-reliance, anthropomorphizing, and algorithmic aversion among human "checkers" reviewing agent outputs)[59].

Alongside NIST AI 600-1, the Chief Architect should utilize ISO/IEC 42001 and AIUC-1 as dual procurement and validation benchmarks[59]. While ISO/IEC 42001 specifies requirements for an overarching Artificial Intelligence Management System (covering bias detection, transparency, and risk governance), AIUC-1—developed with Stanford, MIT, MITRE, and the Cloud Security Alliance—is the first technical standard focused specifically on how AI agents behave under pressure in production environments[59]. AIUC-1 covers data protection, operational boundaries, attack resistance, and error prevention through independent technical testing, and mandates quarterly adversarial red-teaming[59]. Combining ISO/IEC 42001 governance with AIUC-1 quarterly adversarial testing is essential to defend the bank against the escalating threat of AI-enabled financial crime: according to Sumsub's Identity Fraud Report 2025–2026, sophisticated multi-step fraud attacks combining synthetic identities, deepfakes, social engineering, and autonomous agentic attack chains rose 180% year-on-year to reach 28% of all identity fraud in 2025 (with deepfake fraud surging 1,100% and synthetic document fraud rising 311% in Q1 2025 alone), driving projected generative AI fraud losses toward $40 billion in the US by 2027[64].

Curated Architectural & Strategic Reading List: Books and Reports

To equip the Chief Architect, the Architecture Review Board, and lead engineering squads with practical, production-tested methodologies—replacing generic consulting slideware—the following books and regulatory/technical reports represent the definitive 2026 curriculum[46].

Resource Title & Author / Issuing Body	Category & Focus	Target Internal Audience	Core Practical Value for the Bank's AI Transformation
AI Engineering: Building Applications with Foundation Models — Chip Huyen (O'Reilly,	Foundational Engineering Book	Chief Architect, Lead AI/Software Engineers	The premier systems-level framework for deciding between prompting, RAG, agentic workflows, and fine-tuning;

2025)[65]			covers evaluation benchmarks, dataset engineering, latency/cost trade-offs, and inference optimization (Polish translation also in progress)[65].
Designing Machine Learning Systems — Chip Huyen (O'Reilly, 2022)[65]	Production MLOps & Data Systems Book	MLOps Leads, Data Architects, Model Risk Teams	Solves the "60% model degradation in 6 months" problem[1]; provides rigorous engineering patterns for data distribution shifts, feature stores, continual evaluation, retraining pipelines, and enterprise ML platform design[65].
LLM Engineer's Handbook — Paul Iusztin & Maxime Labonne[65]	End-to-End LLMOps Lifecycle Book	Senior AI Engineers, Platform Engineering	Bridges the gap between "duct-taping GPT calls in a notebook" and running observable, maintainable production services; details data pipelines, fine-tuning, evaluation harnesses, and LLMOps monitoring[65].

Building Agentic AI Systems — Anjanava Biswas & Wrick Talukdar[66]	Multi-Agent Systems Book	Agentic Workflow Architects, Squad Leads	Dedicated engineering blueprint for designing autonomous agents capable of multi-step planning, external tool invocation, memory management, and bounded environment interaction[66].
Building LLMs for Production — Louis-François Bouchard & Louie Peters[66]	Production Scaling & Reliability Book	Infrastructure & AI Reliability Engineers	Focuses on the unglamorous engineering work of deploying, scaling, quantizing, and maintaining reliable LLM applications under live enterprise traffic constraints[66].
Build a Large Language Model (From Scratch) — Sebastian Raschka, PhD & ***Hands-On Large Language Models*** — Jay Alammar & Maarten Grootendorst[65]	Deep Model Mechanics & Intuition Books	Internal FinLLM Teams (e.g., Sovereign 1B–24B builders)	Essential for teams training or fine-tuning sovereign Polish financial models[12]; demystifies attention mechanisms, tokenizers, embeddings, and pre-training/post-training mechanics under the hood[65].
Prompt Engineering for LLMs — John	Context Engineering & Distributed Data	Application Developers, Core	Berryman & Ziegler treat prompt/context construction as a

Berryman & Albert Ziegler & ***Designing Data-Intensive Applications*** — Martin Kleppmann[66]	Books	Database Architects	rigorous software engineering discipline[66]; Kleppmann provides the foundational distributed systems theory (linearizability, idempotency, consensus) required for DORA-compliant agent databases[23].
AI Act: Implications for the EU Banking and Payments Sector — European Banking Authority (EBA, Nov 21, 2025)[45]	Regulatory Mapping Report	Chief Architect, CRO, Compliance & Legal	Authoritative EU supervisory baseline mapping Annex III High-Risk obligations (credit scoring, AML monitoring) directly against existing banking regulations (CRD/CRR, MiFID II, DORA, GDPR)[42].
NIST AI 600-1: Artificial Intelligence Risk Management Framework: Generative AI Profile — NIST (July 2024)[60]	Operational Risk & Controls Report	AI Governance Hub, CISO, Internal Audit	Provides an auditor-ready risk register vocabulary (12 GAI risks including Confabulation and Human-AI Configuration) and 212 actionable controls mapped to Govern, Map, Measure, and Manage[60].
Rekomendacja W,	Polish Supervisory	Management	The non-negotiable

Komunikat Chmurowy UKNF, & ***Stanowisko UKNF dot. AML/CFT*** — UKNF[52]	Mandates	Board, Chief Architect, AMLRO	local rulebook for Polish banks governing model registers, external model validation, cloud risk estimation (PN-ISO 27005), and senior management AML accountability[52].
Agentic AI in Financial Services: Choosing the Right Pattern for Multi-Agent Systems (AWS) & ***The State of MCP in Financial Services 2026*** (Stacklok)[22]	Technical Architecture Reports	Enterprise Architects, Cloud & Security Leads	Practical reference guides detailing Workflow, Swarm, and Loop multi-agent patterns, Large Singleton/Agent Washing anti-patterns, and VPC-isolated Model Context Protocol benchmarks across 100 financial services tech leaders[22].
Putting AI to Work: The Enterprise AI Playbook (BCG), ***Evident AI Index for Payments (Feb 2026)***, & ***Sumsub Identity Fraud Report 2025–2026***[19]	Executive Benchmarking & Threat Reports	Executive Committee, Fraud & Payments Heads	Quantifies banking peer governance maturity and details the 180% surge in multi-step agentic/deepfake fraud attacks that defensive banking architectures must counter[19].

Rather than distributing these texts passively, the Chief Architect should structure an internal architectural enablement curriculum tailored to three distinct engineering and governance constituencies[65]. For the Core Platform and AI Engineering Guild, pairing Chip Huyen's *AI Engineering* (2025) with Paul Iusztin and Maxime Labonne's *LLM Engineer's Handbook* establishes a unified systems engineering baseline[65]. Huyen's framework prevents squads from

prematurely fine-tuning models when structured RAG and context engineering are more cost-effective, while instituting rigorous evaluation pipelines that balance response quality, latency, and token economics[65]. When squads advance to multi-agent orchestration, Anjanava Biswas and Wrick Talukdar's *Building Agentic AI Systems* and Louis-François Bouchard and Louie Peters' *Building LLMs for Production* should be combined directly with the AWS Financial Services multi-agent pattern guide to standardize when to deploy sequential Workflows versus concurrent Swarms[22].

For the Sovereign Model and Data Science teams—particularly as Polish banks follow PKO BP's trajectory in developing specialized Polish-language financial models (1B to 24B parameters) or adapting open-source weights like *Bielik* and *Sójka*[12]—Sebastian Raschka's *Build a Large Language Model (From Scratch)*, Jay Alammar and Maarten Grootendorst's *Hands-On Large Language Models*, and Chip Huyen's *Designing Machine Learning Systems* provide the mathematical and MLOps rigor required to prevent overfitting, correlation-driven errors on imbalanced data, and post-deployment data drift[3]. Finally, for the Architecture Board, Risk, and Compliance functions, synthesizing the EBA November 2025 Factsheet, NIST AI 600-1, and UKNF's *Rekomendacja W* into a single internal "Agentic Architecture Standard" establishes a common taxonomy between software engineers and Model Risk Management, eliminating the translation gap that typically stalls production sign-offs[2].

Actionable 180-Day Execution Roadmap for the Chief Architect

To demonstrate immediate, concrete momentum to the Management Board—distinguishing an engineering-led strategy from failed consulting engagements—the Chief Architect should execute a disciplined, three-phase 180-day rollout[1].

Execution Phase & Horizon	Core Architectural & Organizational Deliverables	Target Production Systems & Governance Milestones	Measurable Success Criteria & Risk Controls
Phase 1: Foundation, Triage & Governance Harness (Days 1–60)	Abolish isolated innovation labs; establish **Hub-and-Spoke** charter; deploy **Enterprise AI Gateway** (Redis semantic cache + prompt guards) and **VPC MCP Registry**[2].	Unify **Rekomendacja W** Model Register, **DORA** Register of Information, and **EU AI Act Annex IV & Art. 12** logging schemas (ISO/IEC DIS 24970 Clause 8.3.1)[42].	100% of candidate backlog filtered via 6-point Use-Case Triage; legacy High-Risk credit/AML models audited for Aug 2026 compliance[5].

Phase 2: Parallel Augmented MVPs (Days 61–120)	Launch two 90-day parallel production MVPs inside P&L Spokes using **LangGraph Maker-Checker** checkpoints and read-only **MCP Services**[5].	**MVP 1**: Sovereign Email/Complaint Triage Agent (Workflow pattern)[12]. **MVP 2**: Internal NL-to-SQL & Regulatory Knowledge Swarm[12].	Sub-100ms MCP context retrieval; 40%–70% inference cost reduction via semantic cache; UKNF 30-day cloud notification filed if applicable[9].
Phase 3: Transactional Hardening & Scale (Days 121–180)	Harden distributed SQL storage tier for agent writes; institutionalize **DORA Kill-Switch Drills** and quarterly **AIUC-1 / NIST AI 600-1** red-teaming[7].	Promote reusable MCP services (Customer Context, Ledger Read, Policy KB) to central catalog to scale toward **30+ production agents**[10].	Verified 0 post-stop actions in Kill-Switch drill; <4-hour DORA incident reconstruction readiness; positive MVP ROI trajectory by Month 5[7].

Phase 1: Architectural Foundation, Triage, and Governance Harness (Days 1–60)

During the first 60 days, the Chief Architect must dissolve standalone innovation sandboxes that lack P&L sponsorship and formally institute the Federated Hub-and-Spoke charter[2]. The Central Architecture Hub assumes ownership of the Enterprise AI Gateway, the VPC-isolated MCP Control Plane, and the unified regulatory compliance harness, while embedding Spoke engineering pods directly inside two high-value business units, such as Operations/Complaints and Corporate/Credit Analytics[2]. Simultaneously, the Hub must stand up the AI Gateway integrated with corporate OIDC/SAML identity providers, Redis 8.0 vector semantic caching, and semantic prompt guards, alongside the internal MCP Registry enforcing the seven financial MCP governance rules (default read-only access, zero shared tokens, tokenized PII, and semantic layer grounding)[8]. On the regulatory front, the Hub must unify the bank's existing *Rekomendacja W* Model Register (*Rejestr modeli*) and DORA Register of Information to incorporate EU AI Act Annex IV technical documentation and Article 12 / ISO/IEC DIS 24970 Clause 8.3.1 logging schemas, ensuring all legacy high-risk credit scoring and AML models complete self-assessed conformity and human-oversight verification ahead of the August 2, 2026 enforcement deadline[42].

Phase 2: Parallel Production MVPs in Augmented Operations (Days 61–120)

In the second 60-day window, the bank executes its six-point Use-Case Triage to reject speculative slide-deck ideas and launches two parallel 90-day production MVPs tested on real

users against written pass/fail hypotheses[5]. Both MVPs must be architected as employee augmentation systems enforcing Maker-Checker human-in-the-loop controls rather than unconstrained customer-facing autonomy[4]. Drawing directly from the proven Polish production playbooks of PKO Bank Polski and mBank, the first MVP should deploy an Autonomous Triage and Correspondence Agent (modeled on PKO BP's sovereign email agent and mBank's *mComplaints*) utilizing a sequential Workflow Pattern in LangGraph to ingest customer messages, extract document context via OCR and GenAI, query read-only core banking MCP servers for account history, classify urgency, and pause at a checkpoint for one-click advisor approval[12]. The second MVP should deploy an Internal "Talk to Your Data" and Regulatory Analyst Assistant (modeled on mBank's NL-to-SQL tool and PKO BP's *szukAI*) utilizing a Swarm Pattern connected via MCP to a governed finance semantic layer, enabling risk, compliance, and corporate analysts to query tens of thousands of database tables and internal policy documents with full citation lineage[12]. During this phase, the architecture team must also benchmark hybrid unit economics—comparing public cloud LLM APIs (governed under the UKNF Cloud Communiqué 30-day notification and PN-ISO 27005 risk estimation regime) against on-premise or VPC-hosted sovereign Polish financial models (1B to 24B parameters) and on-premise speech-to-text pipelines to cap long-term operational expenditure[12].

Phase 3: Transactional Hardening, Kill-Switch Drills, and Scale (Days 121–180)

In the final 60-day phase, before permitting any AI agent to execute state-changing writes or payment workflows, the Chief Architect must verify the five pre-deployment DORA database controls at the storage layer: append-only tamper-evident audit logs, per-agent cryptographic identity attribution on every write, strong linearizable read consistency across nodes, storage-layer idempotency keys, and automated compensating transactions[23]. The bank must then conduct and time its first live DORA Kill-Switch Drill—proving zero post-stop actions, generating a complete write rollback manifest, and verifying dual-control restart approval—while verifying that its replayable run logs allow forensic teams to reconstruct any major agent incident well within DORA's mandatory 4-hour regulatory reporting window[7]. Concurrently, the security team initiates quarterly adversarial red-teaming aligned with AIUC-1 and NIST AI 600-1 to test defenses against confabulation, prompt injection, and human automation bias[59]. Once the foundational MCP services (Customer Context, Product Catalog, Regulatory Knowledge Base, and Core Ledger Read) are hardened and audited in production, the Central Hub exposes them as reusable building blocks across additional business unit Spokes, enabling the institution to scale systematically from its initial two MVPs to 30 or more production agents without duplicating integration code or regulatory reviews[10].

Works cited

1. AI Strategy & Roadmap Assessment: How Enterprises Avoid 88% AI, https://www.improving.com/thoughts/ai-strategy-and-roadmap-assessment/
2. AI scaling is not failing in financial institutions. It's being blocked., https://www.projectivegroup.com/ai-scaling-is-not-failing-in-financial-institutions-its-

being-blocked/
3. Why AI Projects Fail? 20 Root Causes and the Path to Success, https://softteco.com/blog/why-ai-projects-fail
4. Generative AI in Banking: Push Past Proof of Concept Fatigue, https://www.cognizant.com/us/en/insights/insights-blog/how-to-operationalize-generative-ai-in-banking
5. AI Consulting for Financial Services in the UK: What to Expect, https://innovify.com/insights/ai-consulting-financial-services-uk
6. Why most enterprise AI projects stall before they scale - IBM, https://www.ibm.com/think/insights/why-most-enterprise-ai-projects-stall-before-scale
7. DORA Compliance for AI Agents - moring.ai, https://www.moring.ai/blogs/dora-compliance-ai-agents/
8. How Model Context Protocol Transforms Financial Analysis - Daloopa, https://daloopa.com/blog/analyst-best-practices/model-context-protocol-strategy-game-changer-for-financial-analysis
9. How AI Gateways Enable Scalable AI Connectivity - Kong Inc., https://konghq.com/blog/enterprise/ai-gateways-for-scalable-ai-connectivity
10. MCP: Secure AI Agents for Financial Systems - Arcade.dev, https://www.arcade.dev/blog/enterprise-mcp-guide-for-fintech-financial-institutions/
11. Aktualne wyzwania prawne związane z zastosowaniem AI ... - PABWIB, https://pabwib.pl/produkt/aktualne-wyzwania-prawne-zwiazane-z-zastosowaniem-ai-w-polskim-sektorze-bankowym/
12. PKO Bank Polski ma pierwszego agenta AI i szybciej odpowie na, https://www.pkobp.pl/media/aktualnosci/informacje-o-banku/pko-bank-polski-ma-pierwszego-agenta-ai-i-szybciej-odpowie-na-maile-klientow
13. GenAI to nie eksperyment. To świadoma, strategiczna decyzja banku, https://itwiz.pl/genai-to-nie-eksperyment-to-swiadoma-strategiczna-decyzja-banku/
14. ING uruchamia pilotaż Asystenta AI opartego na GenAI w ING, https://media.ing.pl/informacje-prasowe/926/pr/862367/ing-uruchamia-pilotaz-asystenta-ai-opartego-na-genai-w-ing-business
15. Agent AI zrealizował pierwszą w Polsce transakcję przy ... - Cashless, https://www.cashless.pl/18971-agent-ai-zrealizowal-pierwsza-w-polsce-transakcje-przy-pomocy-rozwiazania-mastercarda
16. PKO BP uruchomił pierwszego agenta AI, który obsłuży klientów, https://inwestycje.pl/biznes/pko-bp-uruchomil-pierwszego-agenta-ai-ktory-obsluzy-klientow-nawet-70-szybciej/
17. mBank i PKO BP w gronie europejskich banków biorących udział w, https://bank.pl/mbank-i-pko-bp-w-gronie-europejskich-bankow-bioracych-udzial-w-eksperymentalnych-zakupach-z-agentem-ai-od-visa/
18. GenAI w mBanku: wsparcie dla pracowników i jeszcze lepsza jakość, https://pl.media.mbank.pl/406922-genai-w-mbanku-wsparcie-dla-pracownikow-i-jeszcze-lepsza-jakosc-obslugi
19. From PoC to Production: Scaling Enterprise AI Without Failing, https://aiconference.london/news/from-poc-to-production-scaling-enterprise-ai-with

out-failing-august-2026-20260803-12
20. Agentic AI in Banking Guide - Creatio, https://www.creatio.com/glossary/agentic-ai-in-banking
21. Agentic AI in Banking: How to Get Started - Neurons Lab, https://neurons-lab.com/articles/agentic-ai-in-banking/
22. Agentic AI in Financial Services: Choosing the Right Pattern for Multi, https://aws.amazon.com/blogs/industries/agentic-ai-in-financial-services-choosing-the-right-pattern-for-multi-agent-systems/
23. DORA Database Requirements for AI Agents - Cockroach Labs, https://www.cockroachlabs.com/blog/dora-database-requirements-ai-agents/
24. Kong AI Gateway vs LiteLLM, https://konghq.com/blog/enterprise/kong-ai-gateway-vs-litellm
25. AI and Model Context Protocol in Banking: Transforming Financial, https://medium.com/@balarampanda.ai/ai-and-model-context-protocol-in-banking-transforming-financial-services-through-intelligent-agent-71ae00c1bfea
26. Planner-Executor vs. Graph-Based Orchestration (LangGraph) in, https://www.c-sharpcorner.com/article/planner-executor-vs-graph-based-orchestration-langgraph-in-banking
27. Human in the loop tutorial - AI agents - IBM, https://www.ibm.com/think/tutorials/human-in-the-loop-ai-agent-langraph-watsonx-ai
28. Human-in-the-loop AI agents: governance design patterns - Dataiku, https://www.dataiku.com/blog/human-in-the-loop-ai-agents
29. Human-in-the-Loop AI: Time-Travel Workflows with LangGraph, https://christianmendieta.ca/human-in-the-loop-ai-time-travel-workflows-with-langgraph/
30. LangGraph Human in the Loop: Ultimate AI Workflow Guide 2026, https://www.skakarh.com/blog/langgraph-human-in-the-loop
31. LangGraph for Complex Enterprise Workflows with AI Agents, https://www.auxiliobits.com/blog/how-langgraph-enables-complex-enterprise-workflows-with-ai-agents/
32. Agentic AI in Finance and Accounting: The 2026 CFO Guide, https://assistents.ai/blogs/agentic-ai-in-finance-and-accounting
33. AI Use Cases in Banking: Agentic AI for Bank and Credit Union, https://www.botminds.ai/guides/banking
34. AI Gateway Benchmark: Kong AI Gateway, Portkey, and LiteLLM, https://konghq.com/blog/engineering/ai-gateway-benchmark-kong-ai-gateway-portkey-litellm
35. Kong vs LiteLLM: Architecture, Pricing, and Trade-Offs - TrueFoundry, https://www.truefoundry.com/blog/kong-vs-litellm
36. Announcing Kong AI Gateway 3.8 With Semantic Caching and, https://konghq.com/blog/product-releases/ai-gateway-3-8
37. Redislabs-Solution-Architects/kong-ai-gateway-demo - GitHub, https://github.com/Redislabs-Solution-Architects/kong-ai-gateway-demo
38. What is Model Context Protocol and what does it mean for lending?,

https://www.loanpro.io/blog/what-is-model-context-protocol/
39. What Is Model Context Protocol (MCP) for Finance? - Keboola, https://www.keboola.com/glossary/model-context-protocol-for-finance
40. MCP: The next frontier for financial markets - LSEG, https://www.lseg.com/en/insights/mcp-the-next-frontier-for-financial-markets
41. MCP Platform for Financial Services - Stacklok, https://stacklok.com/industry/financial-services/
42. EU AI Act for Financial Services: What Banks & Insurers Must Do, https://alicelabs.ai/en/insights/eu-ai-act-for-financial-services
43. AI Core Banking Analyst | Cory Bankson | FluxForce, https://www.fluxforce.ai/ai-agents/ai-core-banking-analyst
44. AI Open Banking Analyst | Piers Openfield - FluxForce AI, https://www.fluxforce.ai/ai-agents/ai-open-banking-analyst
45. AI Act: implications for the EU banking and payments sector, https://www.eba.europa.eu/sites/default/files/2025-11/d8b999ce-a1d9-4964-9606-971bbc2aaf89/AI%20Act%20implications%20for%20the%20EU%20banking%20sector.pdf
46. The EU AI Act's Logging Requirements Are Clear. - Medium, https://medium.com/@veritaschain/the-eu-ai-acts-logging-requirements-are-clear-27c5a600ef30
47. EBA factsheet: AI Act implications for the EU banking and, https://www.bankingnewsai.com/ai-regulation/documents/eba-ai-act-factsheet-2025
48. Is Your AI System High-Risk? The EU AI Act Classification Guide, https://www.euaiact.com/blog/eu-ai-act-high-risk-classification
49. EU AI Act For High Risk AI in a Nutshell - LCFI, https://www.lcfi.ac.uk/news-events/blog/post/eu-ai-act-for-high-risk-ai-in-a-nutshell
50. Digital Operational Resilience Act: A Complete Guide - Zenity, https://zenity.io/academy/digital-operational-resilience-act
51. Bridging the AI Governance Gap in Financial Institutions - Bird & Bird, https://www.twobirds.com/en/insights/2026/bridging-the-ai-governance-gap-in-financial-institutions
52. Stanowisko UKNF dotyczące Procedury AML/CFT - Legal Geek, https://legalgeek.pl/blog/aml-stanowisko-uknf-procedura-aml-cft/
53. Komunikat Chmurowy KNF – nowe obowiązki dla sektora ... - EY, https://www.ey.com/pl_pl/insights/biuletyn-ryzyka/komunikat-chmurowy-knf-nowe-obowiazki-dla-sektora
54. Komisja Nadzoru Finansowego Rekomendacja W, https://www.knf.gov.pl/knf/pl/komponenty/img/knf_137749_Rekomendacja_W_42219.pdf
55. AI Governance dla rad nadzorczych banków | Rama 2026, https://thinking.inc/pl/boss-articles/uslugi-finansowe-governance/
56. Zarządza Zarządzanie ryzykiem modeli - Warszawa - KNF, https://www.knf.gov.pl/knf/pl/komponenty/img/publikacja_zarzadzanie_ryzykiem_modeli_92496.pdf

57. Cloud computing - komunikat chmurowy KNF - O co chodzi?, https://rpms.pl/komunikat-chmurowy-knf-o-co-chodzi-z-przetwarzaniem-informacji-w-chmurze-obliczeniowej/
58. Chmura obliczeniowa w sektorze bankowym na świecie, w Europie, https://www.zbp.pl/zbp/media/zbp/aktualnosci/wydarzenia/kwiecien%202020/cloud/raport-cloud.pdf
59. AI Agent Compliance for Financial Services (2026) - Fin AI, https://fin.ai/learn/evaluate-ai-agent-compliance-financial-services
60. NIST AI 600-1 Generative AI Profile | OneClickComply, https://oneclickcomply.com/standards/nist-ai-600-1
61. NIST AI RMF Generative AI Profile (NIST AI 600-1) — The 12 Risks, https://docs.modulos.ai/frameworks/nist-ai-rmf/generative-ai-profile
62. Artificial Intelligence Risk Management Framework - NIST, https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence
63. Generative AI Profile: A Clear Guide to the 12 NIST AI Risks, https://governancedocs.com/nist-ai-rmf-generative-ai-profile/
64. AI readiness in financial crime: Deployment, understanding and, https://thepaymentsassociation.org/article/ai-readiness-in-financial-crime-deployment-understanding-and-operational-capability/
65. I Read 20+ Books on AI Engineering and LLMs — Here Are My Top, https://medium.com/javarevisited/i-read-20-books-on-ai-engineering-and-llms-here-are-my-top-5-recommendations-for-2026-70a3d4976fea
66. I Read 20+ Books on AI and LLM Engineering: Here Are My Top 10, https://dev.to/somadevtoo/i-read-20-books-on-ai-and-llm-engineering-here-are-my-top-10-recommendations-3ab
67. Books - Chip Huyen, https://huyenchip.com/books/
68. Designing Machine Learning Systems: An Iterative Process for, https://www.goodreads.com/book/show/60715378
69. Stop Watching AI Tutorials. Read These 6 Books to Become a Real, https://www.youtube.com/watch?v=XKa-1vTLLsk
70. NIST AI 600-1: The Generative AI Profile Explained, https://trussed.ai/resources/nist-ai-600-1-the-generative-ai-profile-explained